

□ Topics:

1. Fundamentals
2. Various attack vectors
3. Defense Mechanism
4. Miscellaneous Topics
 - Risk Management
 - Forensic → Digital
 - IT audit

* What is Cyberspace?

* Information Security vs Cybersecurity.

→ IS is the bigger one. CS falls under it.
 involves both physical & online breach.



* Cyber-attack vs cyber-crime vs cyber-terrorism
 vs cyber-warfare

<u>attack</u> vs <u>crime</u> the tools/technique the offence - extorting money etc.	<u>terrorism</u> when country/nation 60 target 40 (massive scale) → has social, political impact.
---	---

warfare → state first involved AT 200
 → related to military (includes state sponsored actors/entity/org.)

Lebanon - Iran, 200, Indian ↔ Pakistan.

Russia → Ukraine

* Iceberg - parts of the Internet visible to us.

* Surface web

↳ we use this part

* Dark web

↳ authentication
etc.

* Deep Web

↳ cryptocurrency
bitcoin,
Crime - জাভ

Q. - এটা CIA triad এর কোন principle-কে

attack করে।
violate

29/6/26

Class #2

CIA Triad

* Confidentiality - → encryption

- secrecy of info.

* integrity - → Hashing (2 ta hash compare করে)
receiving data exactly as it
was transmitted (not altered)

* availability -

* Virus vs malware
↓ self-replicating ↓ Portmanteau

malware → malicious + software
↓
umbrella (under which there
is virus, worm, ransomware,
trojan horse etc.)

VIRUS (Vital Information and Resources
under Siege)

/Very Important Resources: - - -)

virus
worm
trojan horse
spyware
ransomware
adware

① - Differences between diff. malwares.

Virus - requires a host program, self-replicating (but requires human intervention) & replicates when activated

Worm - self-replicating but doesn't need
① host application

② virus affects ~~apps~~ files etc.
but worm network ~~apps~~

③ virus doesn't need assistance

Trojan Horse - (*) looks like legitimate software but becomes activated if clicked.

Spyware - may not harm, resides inside system & ~~steals~~ ~~apps~~ data.

Ransomware - files encryption করে
 হয়ে যায়, extension change করে দেয়।
 (Dark web-এ হয়) - bitcoin/
 cryptocurrency দিয়ে হয়।

adware - আবেক্ট website-এ redirect
 করে।

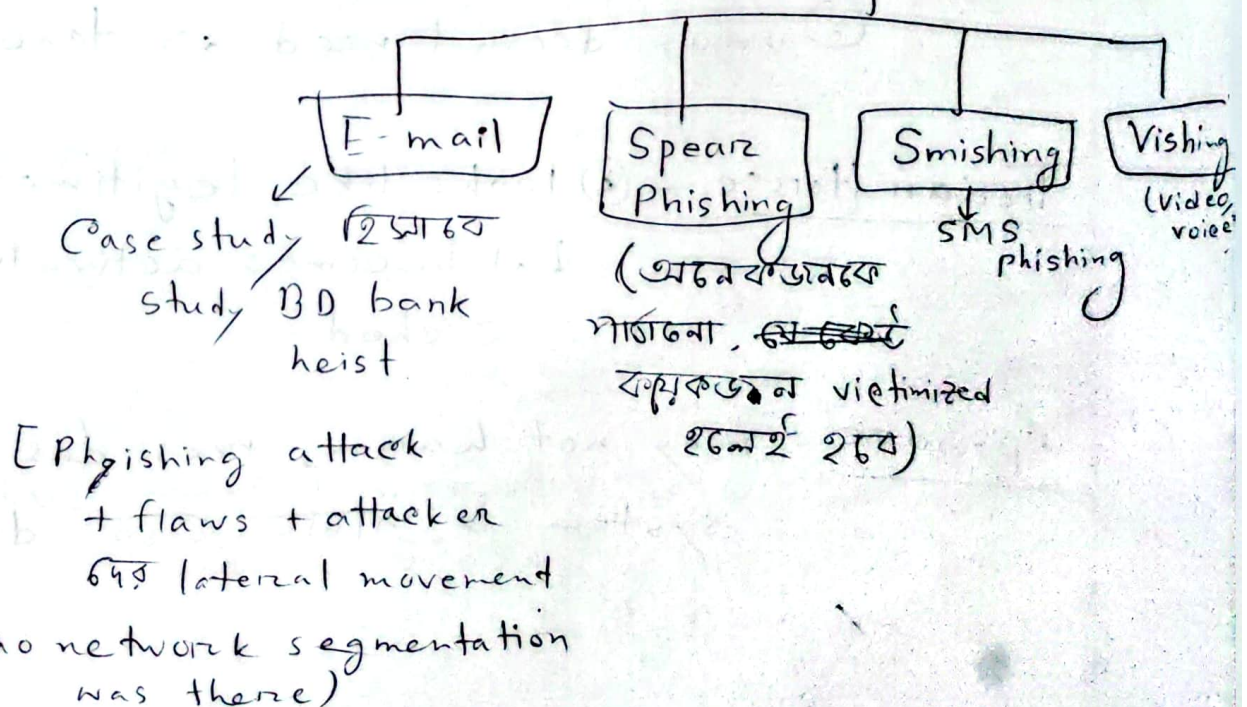
□ Bugs

- code level error
 [ex-syntax / logical
 error.]

□ Flaws

- design level error

□ Social Engineering | □ Phishing attack



indicators:

- * header & email address diff.
- * 'yellow' নেয়া থাকে
- * spelling mistake
- * unusual offers

□ Salami Attack : সন্ধ্যা / small amount keto
(usually banks etc. service charge এর
tieu) তে ফোটে pile up করে)

AAA

- Authentication → "who are you" (genuine user চুকেছে)
- Authorization → privilege/role (কিনা)
assign করা (hierarchy) টি
- Accountability
↓
জবাবদিহিতা
(আপন্য মতটুকু তথ্যটুকুর দ্বারা
Confine থাকা)

(insider threats - one of the most threatening ones).

□ DoS attack

- denial of service attack.

[when services are made unavailable in a network]

* when একটি server-কে clog করে রাখে overloading with traffic.

- comes from single source / attacker

□ DDos attack

- Distributed denial of service attack

- comes from multiple source. (bot-এর মাধ্যমে) / attackers

→ How does this work? / how to attack this way

• OSI model: 7 layers

Application

Presentation

Session

Transport → layer-৩
২য়

Network

Data-link

Physical

• TCP

(secure, connection-oriented)

↓
via 3-way handshake

S $\xrightarrow{\text{req}}$ R

S $\xleftarrow{\text{ack}}$ R

S $\xrightarrow{\text{ack}}$ R

• UDP

(connectionless)

↓
Video streaming-এ
used (when time is most imp.)

- SYN Flood / TCP Flooding
- UDP Flood

↓
এখানে 3 অনেক flow এর
কারণে bottleneck create
হয়।

TCP-65
handshaking-এ
একদিকে অনেক
flow হয় but
পুরা 3 ta
steps শেষ
হচ্ছেনা, clogged.

Brute Force Attack

- all possible cases are tried. (password sniffing
password জানার
জন্য) / OTP/
credentials এর
জন্য
use করা

Solⁿ → ∴ time + no. of tries → limit করে
দেওয়া

Dictionary Attack

→ password guess করার most common technique.

* P@5WORD → one of the
common combinations.

↑
Password sniffing → rainbow
attack
দিয়ে 3 বার
হয়।

Zero Day attack

* updates আছে device-এ (আগের flaws / new
security update নাগতেন - - -)

* attackers বা হ্যাকার এমন কোনো vulnerabilities

আছে কিনা যেটার কোনো prevention নাই।

* **backdoor** - কোনো developers অনেক সময় backdoor রাখে → 1. attackers - যা ~~is~~ zero-day attack - এর জন্য, 2. attacker যা নিজেরা অনেক সময় বেছে যায়, পছন্দ আবার ফেরত আসার জন্য।

Evesdropping



attacker is usually network-এ ঢুকবে

lateral positioning - এর

through - তে move করে & একটি position নেয় & traffic শুনা (packet শুনা controls.

(but doesn't manipulate)

Solⁿ - encryption.

Man-in-the-middle

- similar to evesdropping
- manipulates. (redirects etc.)

* FAT 32 (আবগ ছিল 16)

* NTFS File system * (for this)

□ ARP Spoofing

□ DNS Spoofing

→ next class.

* Self-study :

1. Web Jacking
2. Internet Time of Theft
3. Pepper Attack
4. Industrial Espionage
5. Buffer Overflow Attack
6. Session Hijacking
7. Data Didding
8. E-mail Bombing
9. Cookie Stealing

Class # 4

□ CIA Triad : (Sample ques. for exam)

14/7/26

Q. - If confidentiality is tried to be incorporated
— what impacts on integrity / availability

Q. - * violations of integrity ('man-in-the-middle' attack' & spoofing)
(Impersonification)

(MitM)
→ Sender & receiver
এর মাধ্যমে একজন either
receiver কে send
করেনা / alter ক

Q. * violation of confidentiality (sniffing / phishing (social engineering))

Q. - Bug vs flaw.

→ বেশি অস্থির

* flaw থাকলে system function করবে না - ঠিকানা

→ ex - zero day attacks হতে পারে

Class #5

28/7/26

Keylogger:

10.0.0.2

10.0.0.3

(Sender)

(Receiver)

* Mac to Mac (communication) হয়।

DNS (Domain Name System)

ARP

MAC

maintains a table

works in application layer.

* DNS (When a website is searched, system

doesn't recognize domain name, the match IP address) → so, we create a mapping system.

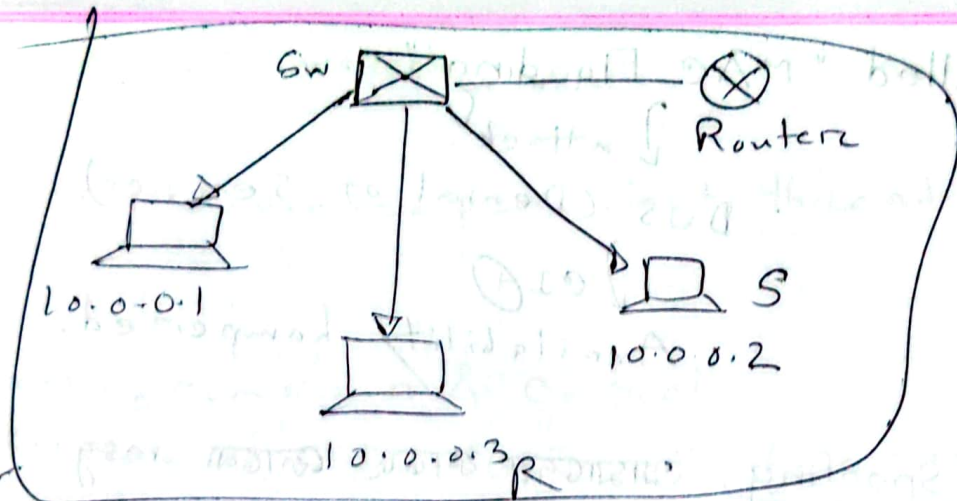
* ARP = Address resolution Protocol

works in Network Layer

maintains a table → (ARP table / MAC Table)

IP addr	MAC address

* MAC → media access control (device - এর physical address) → works in Data-link layer.



Q. Who has the MAC address of this IP? (Broadcast)

2. Reply sent ~~to~~ (Unicast)

∴ সবার কাছে
যাচ্ছে

* এখানেই চুরি ARP spoofing.

* layers:

Application → Network → DL Layer

↓ ↓ ↓
DNS → IP/ARP → MAC

* ARP request = forward Lookup / forward ARP/
(IP ✓) (MAC?) ARP.

* RARP = reverse ARP (MAC address জানা
থাকে, IP addr. দরকার)

* if এখানে devices attacker এর control-এ
থাকে, ওরা অনেক সহজে MAC cloning করে
network cache (যেখানে MAC addr stored
থাকে, সেই cache fill করে ফেলবে & তখন
necessary MAC addr request করে 3 পাওনা যাবনা

TCP flooding SYN

= called "MAC Flooding".

↓ attack

∴ DOS (Denial of Service)

↓ CIA

Availability hampered.

এইটা দিগ
Man-in-the
middle
এক
কিছু

□ IP Spoofing: আমাদের কাছে কোনো msg আসলে,
source IP change করে দেয়।

□ DNS spoofing: Domain name ঠিক আছে but অন্য
website-এ redirect করে (by polluting the
DNS table) → attacker-এর landing station-এ নিয়ে
যায়

□ Key logger: Top intelligence agencies
lip-reading পারে। Computer sys.-এ lip-reader
হচ্ছে key logger (a malicious software) → keyboard-এর stroke, mouse
clicks — সব saved থাকে।
↓
key, board,
mouse

Self
Study

★ ★
(৩) to
(came
in final
2025)

□ SQL injection: 'OR' gate-এ 1 i/p দিলে = 1 হ'ল আর
যা true
যদি কোনো system properly sanitized না থাকে,
then OR function এর through-তে security
bypass করা যায়। Also, used to tamper
data (i.e., i/p field কে alter করে harm আনা)

SIM, SOR, Wazuh → tools.

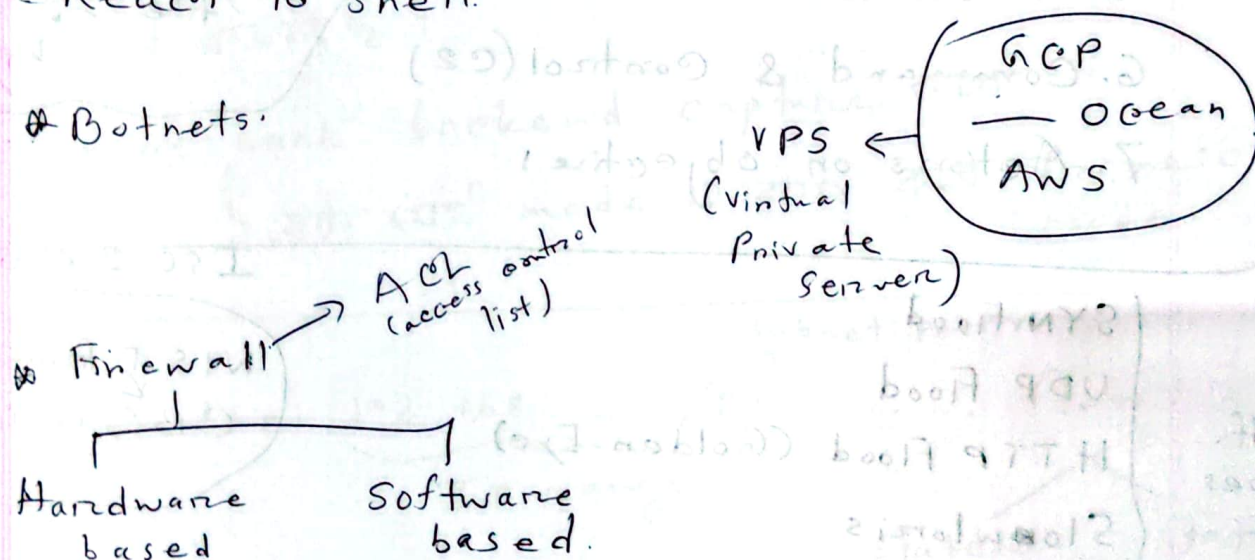
APT → advanced persistent threat (attacker can be anywhere)

* C2 = command & control.

(Main হা জায়গা থেকে attacker operates)

* React to shell.

* Botnets.



* IDS (Suricata, etc. tools)

* OPNsense → BSD based firewall platform
 ↓
 main টা নাম (PFsense)

* Services: cron (scheduled job plan করতে)

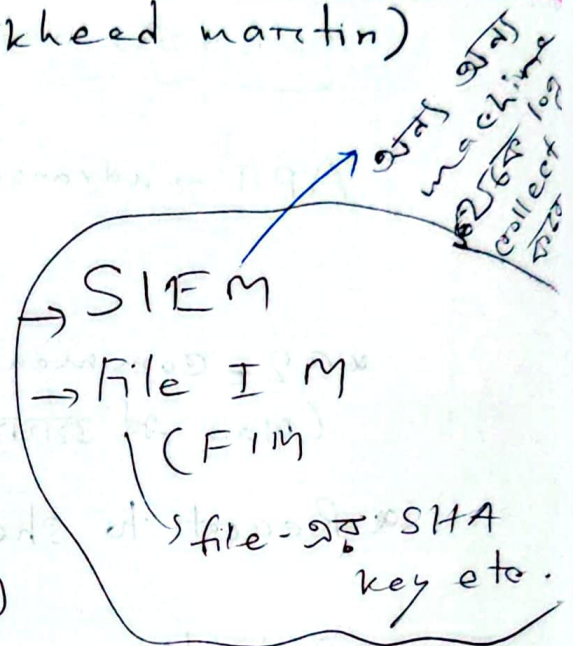
* Firewall এর main কাজ ACL বানাওনা

↓
 source, dst, permissions,
 port etc. (rules
 সূচনা)

tasknet
(Iranian military based)

Cyber Kill Chain (lockheed martin)

1. Reconnaissance
2. Weaponization
3. Delivery
4. Exploitation
5. Installation
6. Command & Control (C2)
7. Actions on objectives



Diff. types of attack

- SYN Flood
- UDP Flood
- HTTP Flood (Golden Eye)
- Slowloris
- ICMP Flood
- HULK HTTP Flood
- TeP RST Flood

ISO 2700

NIST framework
CBSS calculation

before attack in kbps (traffic) → OPSense -> (dashboards)

after " " GBPS

∴ Defense - এর জন্য Rules থানা বসে রাখতে
দিয়েছে

* Whitelisting

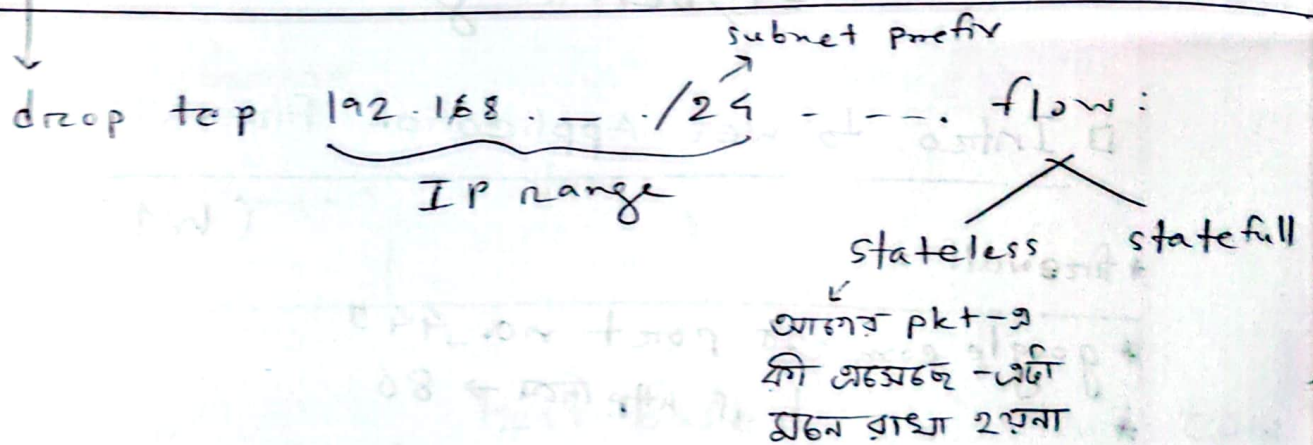
* IDS → (Intrusion detection
& prevention sys)

traffic এর
signature
দেখে detect
করবে

এখানে on sense 'Snuricata' tool কে
add করেছিল।

* Wireshark - backend capture করে

এটা যেই mode-এ কাজ করে Promiscuous
mode.



* classtype: attempted dos.

sid (অনেক rules থাকলে, তখন id no. দিতে
হয়)

* IPS mode = intrusion prevention.

* first-এ signature check করে করে
আলো traffic চুকতে দিবে, প্রতিক্রিয়া block

- 1. SIEM
- * alert triage.
- 2. SOR → "Shuffle" tool
(Security Orchestration & Response - - -)
works on workflow basis.

Wazuh alert → Shuffle (SOR) → যাচাই 3
alert triage করে → OPN sense -
(firewall - ২) পাঠায়

Class # 7

Password of common user

16/8/26

= cybercrange.

Intro. to web Application Firewalls

* firewall = (WAF)

* google.com এর port no. → 443

* " if http দিয়ে → 80

* TLS নামে একটি protocol থাকে → decrypt করা possible না।

* SSL → encrypted msg তা বেছে দেয়,
later decrypt করে।

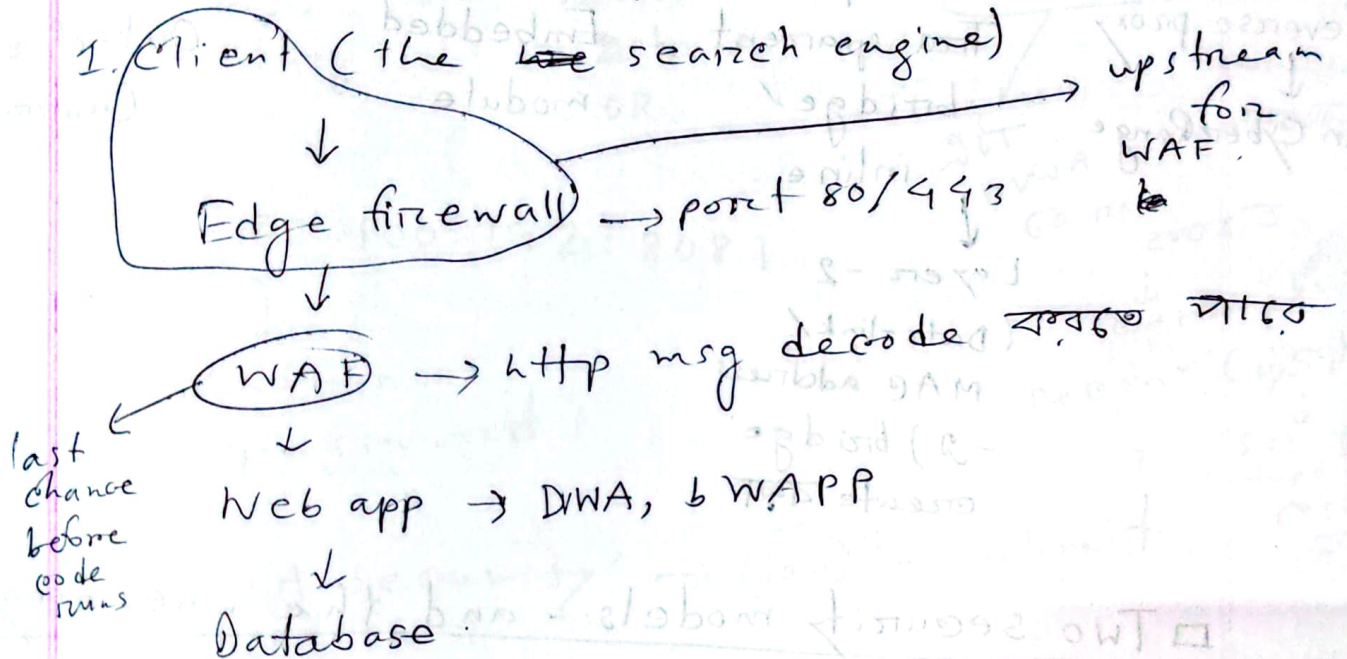
* animo cypher → ww-time এর cypher.

* Perimeter firewall can't read HTTP.

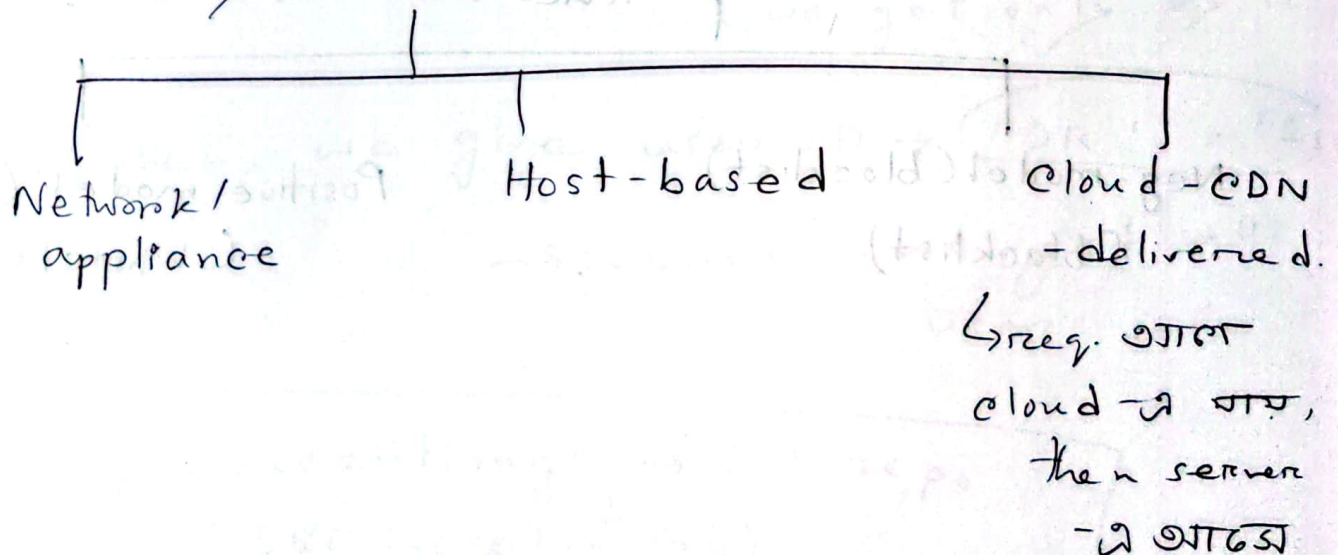
□ WAF → parses, decides, records

* Network Firewall vs IPS/IDS vs WAF

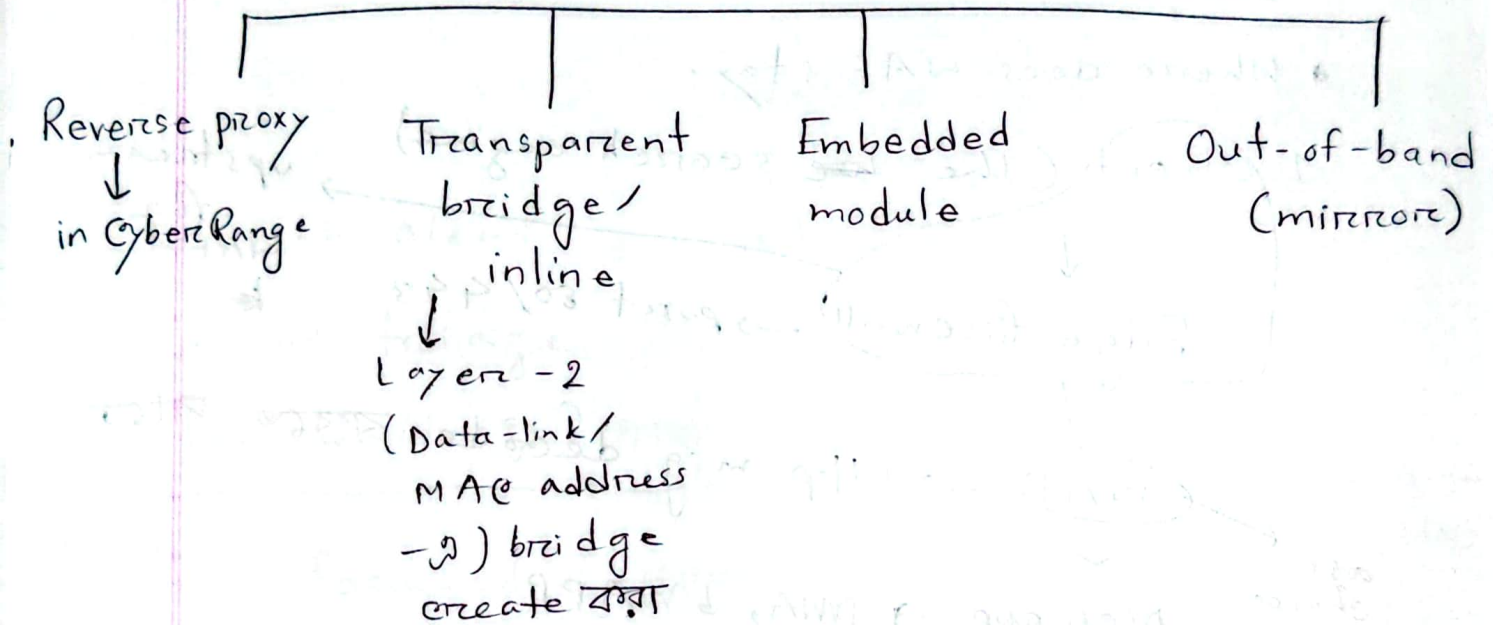
* Where does WAF stay:



□ Deployment modes



□ Operating modes: (how it gets into traffic)



□ Two security models - and the one everyone actually runs:

| rules এমন করে নেয়া

Neg. model (blocklist)
(blacklist)

Positive model (allowlist)
(Whitelist)

'OR '1'='1' = payload

Select * from something where name

= 'OR '1'='1'

means
empty
string

OR

means
true
∴ OR

For Authentication Bypass

'OR '1'='1' (---)

comment
বোঝায়

get
DWA

to run

error but

recon (LijSqlite)

select
type
(সেল
টাইপ)

10.72.100.142:8081

↓

username=admin

password=password

① 'DWA security' → low → submit

② SQL injection → user ID → I → submit
(we get only my info)

& when, we give user ID → 'OR '1'='1'

→ submit → we get all
users info.

★

payload all things → Git repo
(SQL injection tab)

fatal error basically payload syntax
error.

Burpsuite

Offense before defense → slide

↳ 7 phases.

1. Reconnaissance → collects on info on victim (social engineering, open port, employee info.)

* pdf or javascript inject করে, steganography করে

2. Delivery (Payload listing) create করে

3. Exploitation → backdoor করে

4. Installation → কোর payload এর জন্য exploit করে

5. C2 (among all the payloads I send.)

6. Actions on objective.

7. Weaponization.

* write a webshell to disk → installation phase.

GET একটি character নিয়ে, INTO OUTFILE

web root **

* attackers log করে

↓
web site - এর
history এর
file.

* compiler- $\rightarrow$ regex $\rightarrow$ = used to recognize pattern. payload এর ক্ষেত্রে 3 pattern recognize করে

* MITRE attack $\rightarrow$ TTP (Techniques, tactics, procedures).
 $\downarrow$
attack/defense
design করতে এই standard টা maintain করতে হয়।

HTML injection

comment নিয়ন্ত্রণ $\rightarrow$ rendered হবে না

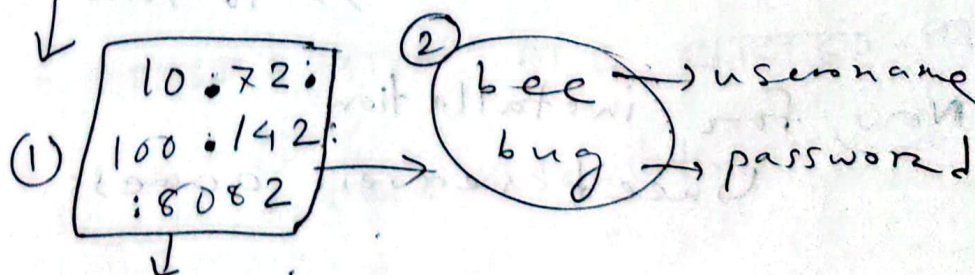
* click jacking (একটা pg এর অন্য আবেশন)

OS Command Injection

so far
(আজকের
class)-এর
dangerous
বৈশিষ্ট্য

Cross Site scripting

attacker runs javascript.

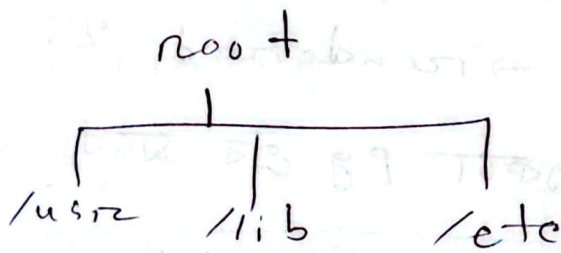


③ Choose your bug $\rightarrow$ OS
Command Injection - Blind

$\rightarrow$ 10.72.100.142 $\rightarrow$ ping

$\downarrow$
CMD তে run করতে পারি

④ $\rightarrow$ 10.72.100.142 && cat /etc/pass



$\rightarrow$ (passwd) - যে সudo etc.
থাকার জন্য
password
stored.

$\rightarrow$ 10.72.¹⁰⁰.142 && ls

so far exploitation
done.

* Now, for installation

need server address.

German provider (had 5000 VMs) →
React 2shell

WAF defense

backend-এ (developers) বা neg. পার্স
fetch / AXIALS etc. plugins দিয়ে

'Mod Security' → Cyber range-এ।

↓
@rx in mod security means → regex way
-তে হবে

\d → যেকোনো digit but একটা

\s → যেকোনো word character

\w → অক্ষর / Zero বাহ

+ → একবার / অনেকবার একটা atleast হবে

\b or \B → boundary.

? → থাকতে 3 গাড়ে, না 3 থাকতে পারে

(?i:) → case insensitive.

Regex

'OR' '1' = '1'

$$['\ "] \backslash s^* \backslash b \text{ or } \backslash b \backslash s^* ['\ "] \backslash d^+ ['\ "] \backslash s^*$$

↓
∴ 'or' হতে পারে
$$['\ "] \backslash s^* \backslash b \text{ or } \backslash b \backslash s^* ['\ "] \backslash d^+ ['\ "] \backslash s^*$$

Mod Security এর logs নিয়ে → SIEM

(Wazuh tool)

2 if threat 2য়
forwards to

Shuffle
N8N } tools.

SOAR → automation
tool

* OPNsense → edge perimeter firewall.

Class # 8

Rev. of ARP & DNS Spoofing → (28/7/26) এর Class

24/8/26

□ IAM (Identity and Access Management)

↓
Authentication

↓
Authorization

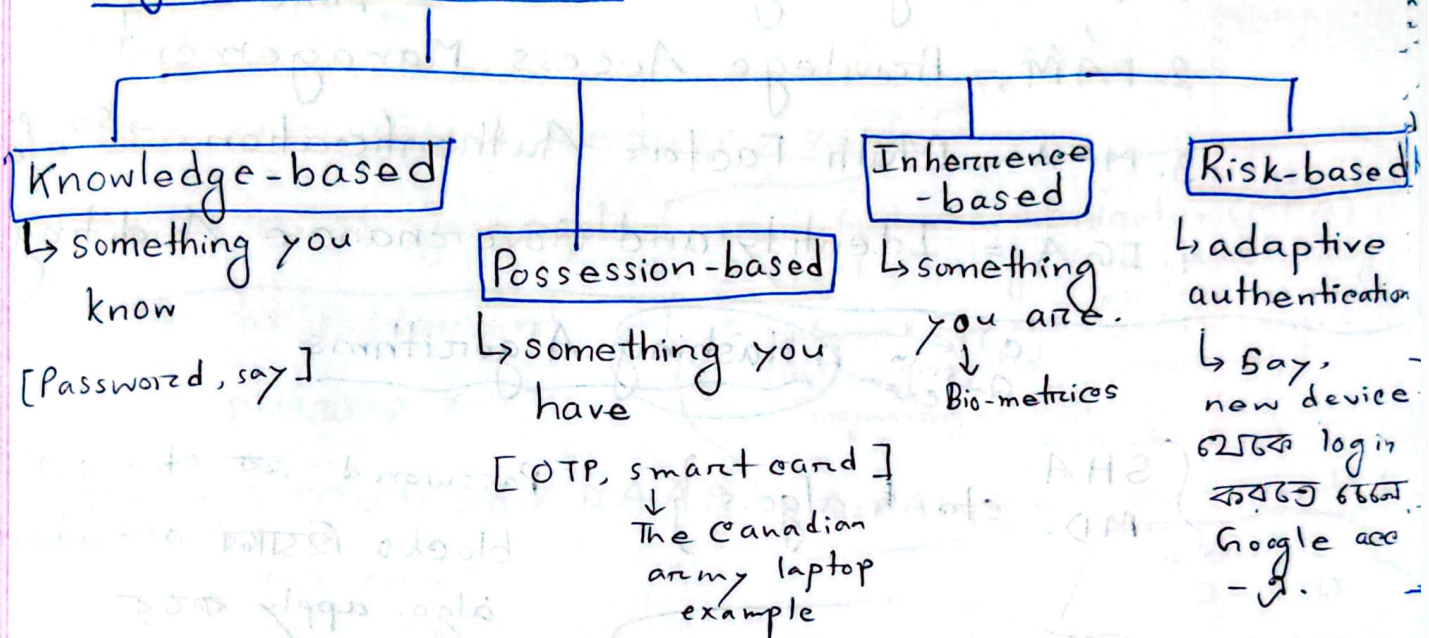
(RBAC গুলি যে)
↓
Role-Based
Access Control

□ Components of IAM:

1. Identification / Identity Provisioning
2. Authentication. → has few standard protocol / we can create our own
3. Authorization → কতটুকু privilege দাবে
4. Auditing → অর্থাৎ ম্যানুয়াল, অর্থাৎ Role-এ থেকেও forgery করে,

logs analysis বঙ্গ, monitoring

□ Digital Authentication:



□ IAM Solution Approaches:

1. On-premises ^{better :: security} → IAM tech is implemented within the MIST network / data center
2. Cloud-based
3. Hybrid ^{security issues} → ∴ everyone can't afford on-premises, ∴ cloud-এ করে (taking yearly / monthly subscriptions)

□ IAM Implementation Phases:

1. Requirement analysis
2. Risk analysis
3. Design → ^{৬০% কাজ} ^{এই পর্যন্ত} ^{সফটওয়্যার উন্নয়ন ওটার ফেক্ট} approach is selected
4. Tool selection
5. Implementation.

6. Testing & Training
7. Monitoring & Auditing

□ IAM tools :

1. SSO = Single Sign On → ex - 'Sign in with Google' → RBAC এর মতো
2. PAM = Privilege Access Management
3. MFA = Multi-Factor Authentication → say, password + OTP
knowledge-based
possession-based
4. IGA = Identity and Governance Auditing

(c) ← in Ques. exam □ Hashing Algorithms

{ SHA
MD etc. & algo.s }

Password - এর string ২লাকে
blocks হিসাবে consider করে
algo. apply করে

Hash table / rainbow
table

hash value never changes.

→ rainbow table attack.
dictionary "
brute-force "

∴ salt + hash value

Solⁿ :

salting

↓ Now,

pepper + salt + hash value

↓
a secret key

extra character
add করা blocks
-২।

Zero Trust Architecture (ZTA)

Contents :

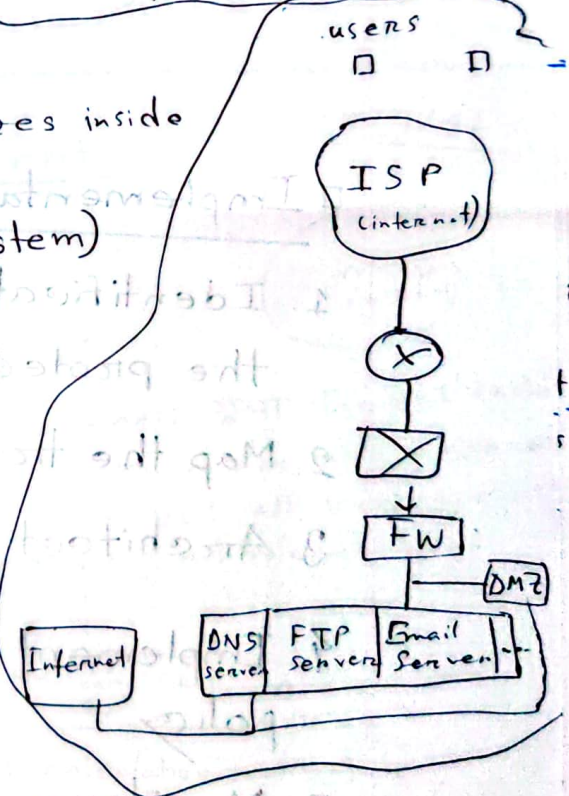
- How zero-trust reduces risk. → left!
- Zero-trust principles
 - 1. Multi-factor authentication (MFA)
 - 2. Least privilege (within RBAC, giving privilege as much as the person needs only)
 - 3. Network Segmentation (Micro segmentation)
 - segmenting as { high sensitive, moderate, less }
 - 4. Risk Adaptive Security Control
- How to implement
- Five pillars. X
- Kipling method / DAAS.
 - not so imp. for exam.

* DMZ → keeps most sensitive services inside (De-militarized zone) or privately

Ex - CBS (Core Banking System)

* Lateral movement ✓ (in the BD Bank case study) → ∴ no network seg. was there

* Vertical movement → moving from layer to layer etc



□ DAAS : Data
Asset
Application
Services

'Protected Surface Area'
যেখানে বসতে হয়।

Kipling method : W-H (6 ques)

Who
When
Where
Why
What
How

'6 men serving'
novel - গ্রন্থ novelist

□ Implementation of ZTA :

1. Identification of protected surface/define the protect surface.
2. Map the transaction flows
3. Architect the Zero Trust Network.
4. Implement the zero-trust policy.
5. Monitoring and maintain the network.

Security Controls

1. MFA /Auth.
2. Network segmen-
-tation
3. Firewall :
NGFW, WAF
(Next gen. firewall) (Web Appli-
-cations Firewall)
4. Sand boxing
quarantine
5. SOC
6. Incidence
Response mech.

BOP = Business Continuity Plan

* ~~if~~ DC -এর data mirroring করে backup রাখা হয়।

* Our DRs are kept in different seismic zones (যাতে diff. tectonic plates এর উপর থাকে)

* SOC এর সাথে IDS, IPS integrated থাকে অনেক সময়।

Data centre Disaster Backup recovery

7. DC/DR security

8. Policy / Regulation

9. IDS ^{deployed in perimeter}

10. IPS.

↳ implemented in the next layer of that of IDS.

৩-৩ (Assignment) → Bashar Sirz
↓
instead of this Thurs

Class#10

Risk Management

7/9/26

Key components of RM:

1. Threat → asset কে ক্ষতিগ্রস্ত করতে পারে

2. Vulnerabilities → system যে weakness খুলা Threat exploit করতে পারে। So, all vuln. are weakness but all weaknesses are not vulnerabilities

3. Impact

4. Asset

5. Control

severity of the threat on vulnerability
likelihood related to it.

very rare 1 rare 2 likely/often 3 very likely 4 certainly 5

heatmap (risk calculation matrix)

risk = (likelihood x impact)

	1	2	3	4	5
1	5	10	15	20	25
2	4	8	12	16	20
3	3	6	9	12	15
4	2	4	6	8	10
5	1	2	3	4	5

↑ impact ↓ likelihood

all system measures (firewall, IDS, ...)

let, $\begin{cases} 1-3 : \text{Low} \\ 4-6 : \text{Medium} \\ 7-12 : \text{high} \\ 13-25 : \text{critical} \end{cases}$

threat, vulnera., impact

Q. - Mention the 3 key components

Q. - if asks all comp. → then all 5.

Control

Administrative
control

let, you deployed
a firewall, but
there is no IT

policy.

means after office hours
no one can log in.

Technical
control

all technical
tools (IDS,
IPS, end point
sec., DDoS protection)
etc.

Physical
control

CCTV,
biometrics,
guard

Control (Based on Functionality)

Detective Control

(detects threats,
attacks)

→ IDS
→ honeypot

(looklike VM-এ system
রে deploy করে trying
to divert attackers to it
& hiding the real system)

Corrective
control

attack 2য় কোন

Preventive control

(attack যাতে না
হয়)

→ IPS

Deterrent
control

Proactive
vs
reactive

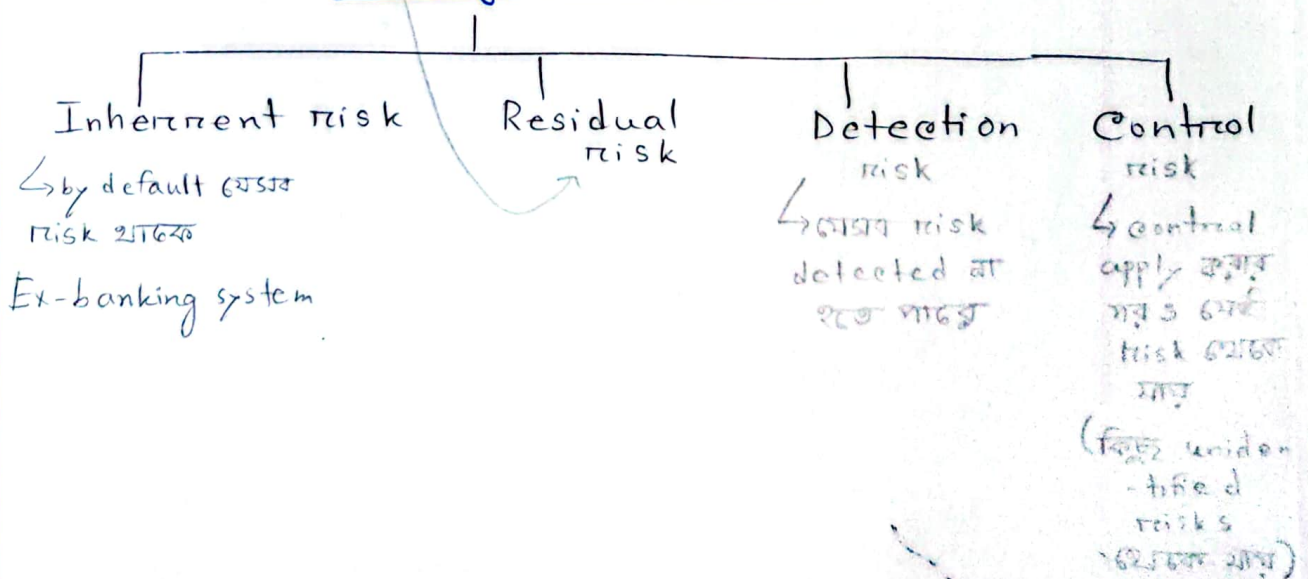
Q. - Fill the table with examples!

	Adminis.	Technical	Physical
Detective			
Preventive			
Corrective			

□ Risk Treatment → how to handle when risk appears.

1. Risk Termination → risk avoid করা
2. Risk Mitigation → control apply করা যা reduce/remove হবে
↓
↓ risk
3. Risk transfer/share → 3rd party service (Assure) থেকে নিশ্চয়, risk আসলে they'll handle
4. Risk accept → risk আসবে জানি, মেনে নিলাম

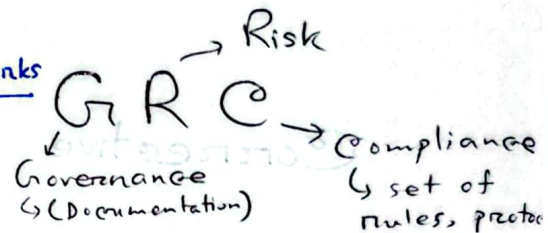
□ Categories of risk / Types



▣ Phases of Risk Management:

1. Risk identification (asset, threat....)
2. Risk assessment (impact, frequency....)
3. Risk Treatment (physical কাজটা ওয়াটন)
4. Monitor, Review & Feedback

▣ Compliance Frameworks



HIPAA → health sector-ও

GDPR → works with data security

PCI DSS → bank's ATM card operation needs this

ISO 27001 → in cybersec

COBIT

NIST CSF

- data still recoverable
- * quick format → deleted files এর part ta empty করে
- * full format → empty + write/fill those with zero
↳ data-not recoverable

* thumb rule of forensic → 1. Original evidence shathe shathe copy করা (ftk imager, DD01, encase etc. tools দিয়ে)

② never ~~work~~ work on the original evidence, hash করে রাখো. later, 2 ta hashing value compare করে same 2ta, okay ✓

③ write blocker দিয়ে write protect করে, bit by bit image করব। (∴ 2 copies করা better)

* Proper chain of custody - তে রাখতে হবে।

* Fat 32, naki others দিয়ে করা → partition recovery, ওই imp. (of hard drive)
(file format)

□ MBR (Master Boot Record) [একটা hard drive কে partition করলে, একটা MBR করি]

↳ জার্বারনত 16 Bytes - এর

Ex- 80010000EF

1st 2 bytes = 1et, বুঝায় bootable কিনা → 80 হলে (1et, non-bootable device)
(প্রতিটা chunk of bytes এর meaning আছে)

* sector, cylinder, head → in hard drive .

(1et, ঐটার starting point next 6 bits বুঝায় -

□ VBR

* for partition → file system জাবা imp. !!

* partition recovery করলে, কিছু file আছে

* file recovery tools (1et, ব্যর্থ হতো), কিছু 'file carving tools' আছে → (if file partition - এ কিছু permission দেওয়া → কিছু file recovery করতে না পারলে used then) ①

□ Disk Imaging Tools:

FTK Imager, Encase, dd (used in Linux);

□ Partition Recovery Tools:

TestDisk, R-Studio, GetData Back.

□ File Recovery Tools: PhotoRec, Foremost, Recuva, Autopsy, Tsk, Encase, X-ways Forensic.

* CT review:

Ques-1 : Worm ✓ / virus (∵ 1 word missing in ques.)
Trojan X (∵ self-replicating at

Ques-2 : Mainly Confidentiality, Availability, Integrity
(২৩৩ নম্বর - ∵ কিছু data back নষ্ট)

Ques - phishing - email, sms etc.